BỘ KHOA HỌC VÀ CÔNG NGHỆ

HỌC VIỆN CÔNG NGHỆ BƯU CHÍNH VIỄN THÔNG

------□□□□□------



BÁO CÁO BÀI THỰC HÀNH

Mô phỏng hệ thống Kerberos Single Sign-On (SSO)

Sinh viên thực hiện: Hoàng Văn Bắc

Mã người thực hành: B22DCAT035

Lớp: D22CQAT035 -B

Giảng viên hướng dẫn: TS. Quản Trọng Thế

Mục lục

DANH MỤC CÁC HÌNH VẼ....3
DANH MỤC CÁC BẢNG BIỂU....3
DANH MỤC CÁC TỪ VIẾT TẮT....3
1.1 Giới thiệu chung về bài thực hành....4
1.2 Nội dung và hướng dẫn bài thực hành....4
1.2.1 Mục đích....4
1.2.2 Yêu cầu đối với người thực hành....4
1.2.3 Nội dung thực hành....5
1.3 Phân tích yêu cầu bài thực hành....6
1.4 Thiết kế bài thực hành....6
1.5 Cài đặt và cấu hình các máy ảo....8
1.6 Tích hợp và triển khai....9
1.6.1 Docker Hub của bài sso-kerberos....10
1.6.2 Github....11
1.7 Thử nghiệm và đánh giá....12
TÀI LIỆU THAM KHẢO....14

DANH MỤC CÁC HÌNH VẼ

Hình 1 Giao diện cấu hình labtainer.....8
Hình 2 Thông tin file Result.....8
Hình 3 File thực hành khi làm labtainer.....9
Hình 4 Dockerfiles của máy sso-kerberos
Hình 5 Commit bài lab và tạo imodule.tar lab sso-kerberos
Hình 6 Đẩy các vùng chứa bài sso-kerberos lên dockerhub
Hình 7 Các vùng chứa bài sso-kerberos được đẩy lên dockerhub
Hình 8 File imodule.tar chứa bài thực hành sso-kerberos
Hình 9 Đẩy file imodule.tar bài sso-kerberos lên github
Hình 10 Tải và chạy bài sso-kerberos
Hình 11 Xác thực Kerberos và truy cập Web SSO thành công
Hình 12 Quét thu thập bản băm AS-REP bằng GetNPUsers
Hình 13 Thực hiện tấn công thám mã bẻ khóa ngoại tuyến
Hình 14 Kịch bản phòng thủ & chặn đứng thám mã (KDC_ERR_PREAUTH_REQUIRED)
Hình 15 Checkwork bài sso-kerberos

DANH MỤC CÁC BẢNG BIỂU

Bảng 1 Result sso-kerberos

DANH MỤC CÁC TỪ VIẾT TẮT

Từ viết tắt	Thuật ngữ tiếng Anh/Giải thích	Thuật ngữ tiếng Việt/Giải thích
Lab	Labtainer	Môi trường thực hành an toàn thông tin

		mạng
SSO	Single Sign-On	Cơ chế xác thực một lần
KDC	Key Distribution Center	Trung tâm phân phối khóa Kerberos
AS	Authentication Server	Máy chủ xác thực người dùng
TGS	Ticket Granting Server	Máy chủ cấp vé dịch vụ
TGT	Ticket Granting Ticket	Vé cấp vé (chứng chỉ xác thực ban đầu)
ST	Service Ticket	Vé truy cập dịch vụ đối tượng
SPNEGO	Simple and Protected GSSAPI Negotiation	Cơ chế đàm phán xác thực mở rộng HTTP (RFC 4559)
GSSAPI	Generic Security Services API	Giao diện lập trình dịch vụ bảo mật chung (RFC 2743)
AS-REQ	Authentication Service Request	Bản tin yêu cầu cấp vé TGT gửi tới KDC
AS-REP	Authentication Service Response	Bản tin phản hồi cấp vé TGT từ KDC
TGS-REQ	Ticket Granting Service Request	Bản tin yêu cầu cấp vé dịch vụ ST
TGS-REP	Ticket Granting Service Response	Bản tin phản hồi cấp vé dịch vụ ST
PAC	Privilege Attribute Certificate	Chứng chỉ thuộc tính đặc quyền người dùng
AES	Advanced Encryption Standard	Chuẩn mã hóa nâng cao (AES256-CTS-HMAC-SHA1-96)
gMSA	Group Managed Service Accounts	Tài khoản dịch vụ quản lý tự động theo nhóm
FAST	Flexible Authentication Secure Tunneling	Đường hầm xác thực an toàn bảo vệ bản tin (RFC 6113)
SIEM	Security Information and Event Management	Hệ thống quản lý thông tin và sự kiện bảo mật
DoS	Denial of Service	Tấn công từ chối dịch vụ

1.1 Giới thiệu chung về bài thực hành

Bài thực hành "Mô phỏng hệ thống Kerberos Single Sign-On (SSO) và tấn công thám mã AS-REP Roasting" giúp người thực hành hiểu được cách thiết kế, vận hành và phân tích chuyên sâu cơ chế bảo mật trong hệ thống xác thực tập trung Kerberos v5 (RFC 4120) kết hợp giao thức Web SPNEGO (RFC 4559). Sau khi hoàn thành bài thực hành, người thực hành có thể nắm vững kiến trúc mạng xác thực phân tán, quy trình trao đổi khóa và cấp phát vé TGT/ST, cách thức kẻ tấn công khai thác thuộc tính DONT_REQ_PREAUTH để thu thập dữ liệu mã hóa AS-REP và tiến hành thám mã bẻ khóa mật khẩu ngoại tuyến (Offline Dictionary Attack), đồng thời thực nghiệm thành công kịch bản phòng thủ: bắt buộc Pre-Authentication (+requires_preauth), nâng cấp chuẩn mã hóa AES-256, chuyển đổi gMSA, thiết lập đường hầm Kerberos Armoring (FAST - RFC 6113) và xây dựng giám sát cảnh báo SIEM.

Trong thực tế, Kerberos được xem là tiêu chuẩn vàng trong các hệ thống mạng miền doanh nghiệp (Active Directory và Linux Realm). Hệ thống dựa trên mô hình trao đổi khóa đối xứng Needham-Schroeder cải tiến với cơ chế chống tấn công phát lại (Replay Attack) bằng dấu thời gian (Timestamp). KDC (Key Distribution Center) chia sẻ các khóa bí mật đối xứng với từng thực thể (Principal). Khóa bí mật của người dùng được sinh ra từ hàm dẫn xuất: K_user = PBKDF2(HMAC-SHA1, P_user, Salt, Iteration).

Cấu trúc toán học bản tin AS-REQ: Khi người dùng khởi tạo phiên làm việc, client gửi bản tin AS-REQ: AS-REQ = { Principal_Client, Principal_Server, E_{K_user} (Timestamp_auth || Nonce_1), Etype_list }. Cơ chế mã hóa dấu thời gian này được gọi là Kerberos Pre-Authentication (PA-ENC-TIMESTAMP). Khi KDC nhận được AS-REQ, KDC sử dụng khóa K_user lưu trong cơ sở dữ liệu để giải mã Timestamp. Nếu chênh lệch thời gian không vượt quá ngưỡng cho phép (mặc định 5 phút), KDC xác thực thành công danh tính người dùng mà không cần truyền mật khẩu qua mạng.

Cấu trúc toán học bản tin AS-REP: KDC đóng gói bản tin phản hồi AS-REP gồm vé TGT và phiên làm việc: AS-REP = { TGT, E_{K_user}(K_{c,tgs} || Timestamp || Lifetime || Nonce_1) }. Trong đó vé TGT có dạng: TGT = E_{K_kdc}(K_{c,tgs} || Principal_Client || Timestamp || Lifetime || PAC). Khi truy cập dịch vụ đối tượng (như Web SSO), client gửi bản tin TGS-REQ: TGS-REQ = { TGT, Authenticator_{c,tgs}, Principal_Service,

Nonce_2 } và nhận về vé dịch vụ ST: TGS-REP = { ST, E_{K_{c,tgs}}(K_{c,s} || Timestamp || Nonce_2) }, với ST = E_{K_service}(K_{c,s} || Principal_Client || Lifetime || PAC).

KỊCH BẢN TẤN CÔNG 1 - THÁM MÃ AS-REP ROASTING (MITRE ATT&CK T1558.004): Vì lý do tương thích ngược hoặc sơ suất cấu hình, thuộc tính DONT_REQ_PREAUTH (UserAccountControl bit 0x400000 - UF_DONT_REQUIRE_PREAUTH) bị kích hoạt trên tài khoản nạn nhân. Khi thuộc tính này bật, KDC lập tức bỏ qua bước kiểm tra PA-ENC-TIMESTAMP và trả về ngay gói tin AS-REP chứa phiên mã hóa E_{K_user}(K_{c,tgs} || ...) cho bất kỳ ai gửi AS-REQ. Kẻ tấn công không cần có tài khoản miền, không cần quyền quản trị, chỉ cần gửi AS-REQ nặc danh là có thể thu về gói tin mã hóa.

KẺ TẤN CÔNG BẺ KHÓA NGOẠI TUYẾN (OFFLINE DICTIONARY ATTACK): Kẻ tấn công trích xuất chuỗi mã hóa AS-REP theo định dạng: $krb5asrep$etype$user@REALM:checksum$cipher. Quá trình bẻ khóa diễn ra hoàn toàn cục bộ trên máy tính của kẻ tấn công: với mỗi mật khẩu ứng viên w_j trong từ điển W, kẻ tấn công tính khóa thử nghiệm K_candidate = String2Key(w_j), giải mã khối dữ liệu và đối chiếu Checksum. Do quá trình diễn ra ngoại tuyến, tốc độ bẻ khóa có thể đạt hàng triệu phép thử/giây trên GPU mà hoàn toàn không kích hoạt chính sách khóa tài khoản (Account Lockout Policy). Ngoài ra, kẻ tấn công cũng có thể khai thác kỹ thuật Kerberoasting (MITRE ATT&CK T1558.003) bằng cách xin vé TGS của các tài khoản dịch vụ chạy SPN và bẻ khóa ngoại tuyến vé ST.

KỊCH BẢN PHÒNG THỦ 1 - BẮT BUỘC PRE-AUTHENTICATION (+requires_preauth): Đây là biện pháp cốt lõi và trực tiếp nhất. Quản trị viên rà soát toàn bộ người dùng miền và kích hoạt cờ +requires_preauth. Khi kẻ tấn công gửi AS-REQ nặc danh, KDC phát hiện thiếu PA-ENC-TIMESTAMP và ngay lập tức phản hồi mã lỗi KDC_ERR_PREAUTH_REQUIRED (error 25), tuyệt đối không gửi bất kỳ khối dữ liệu mã hóa nào, triệt tiêu hoàn toàn khả năng thu thập bản băm của kẻ tấn công.

KỊCH BẢN PHÒNG THỦ 2 - NÂNG CẤP MÃ HÓA AES-256 & CHUYỂN ĐỔI gMSA: (1) Vô hiệu hóa chuẩn mã hóa cũ RC4-HMAC (etype 23 vốn sử dụng NTLM hash dễ bị bẻ khóa), bắt buộc áp dụng chuẩn mã hóa nâng cao AES256-CTS-HMAC-SHA1-96 (etype 18, RFC 3962) với thuật toán dẫn xuất khóa PBKDF2 4096 vòng lặp, nâng chi phí tính toán bẻ khóa lên gấp hàng nghìn lần. (2) Đối với tài khoản dịch vụ, chuyển đổi sang tài

khoản Group Managed Service Accounts (gMSA) với mật khẩu phức tạp 128 ký tự do KDC tự động tạo và thay đổi định kỳ mỗi 30 ngày, vô hiệu hóa hoàn toàn phương thức tấn công từ điển.

KỊCH BẢN PHÒNG THỦ 3 - THIẾT LẬP ĐƯỜNG HẦM KERBEROS ARMORING (FAST - RFC 6113): Flexible Authentication Secure Tunneling (FAST) là cơ chế thiết lập đường hầm mã hóa bảo vệ toàn bộ tiến trình trao đổi bản tin AS-REQ và AS-REP bằng khóa phiên của máy tính trạm (Computer Account Armoring Ticket). Nhờ FAST, ngay cả khi một tài khoản bắt buộc phải tắt Pre-Authentication để tương thích dịch vụ cũ, kẻ tấn công trên mạng nội bộ vẫn không thể trích xuất chuỗi mã hóa AS-REP nếu không có khóa bí mật của máy tính trạm.

KỊCH BẢN PHÒNG THỦ 4 - GIÁM SÁT SIEM VÀ PHÁT HIỆN XÂM NHẬP (DETECTION ENGINEERING): Hệ thống giám sát an ninh SIEM (như Splunk, Elastic SIEM, Wazuh) được cấu hình các luật tương quan giám sát: (1) Windows Security Event ID 4768: Giám sát các sự kiện cấp TGT có Pre-Authentication Type = 0 (tài khoản không dùng Pre-Auth) hoặc mã lỗi Failure Code 0x19 (KDC_ERR_PREAUTH_REQUIRED) xuất hiện với tần suất cao từ một địa chỉ IP; (2) Windows Security Event ID 4769: Giám sát yêu cầu vé dịch vụ TGS sử dụng mã hóa RC4 (Ticket Encryption Type = 0x17 - dấu hiệu Kerberoasting); (3) Cấu hình luật Snort/Suricata Network IDS bắt gói tin Kerberos AS-REQ lặp đi lặp lại nhắm vào nhiều tài khoản người dùng khác nhau.

ĐỘ PHỨC TẠP TÍNH TOÁN VÀ Ý NGHĨA THỰC TIỄN: Độ phức tạp tính toán của thuật toán thám mã phụ thuộc vào không gian từ điển |W| và hàm String2Key. Với RC4-HMAC, việc tính MD4(Unicode(P)) chỉ tốn vài chu kỳ CPU. Ngược lại với AES-256 PBKDF2, hàm HMAC-SHA1 lặp lại 4096 lần đòi hỏi nguồn lực tính toán khổng lồ. Kết hợp chính sách mật khẩu mạnh (độ dài tối thiểu 16 ký tự) và kích hoạt Pre-Authentication, hệ thống đảm bảo an toàn tuyệt đối. Bài thực hành giúp người học trải nghiệm toàn diện vai trò Red Team (tấn công khai thác) và Blue Team (phòng thủ, vá lỗi và kiểm chứng an ninh).

1.2 Nội dung và hướng dẫn bài thực hành

1.2.1 Mục đích

Giúp người thực hành nắm vững và thực hành toàn diện quy trình xác thực một lần Kerberos SSO (HTTP SPNEGO và SSH GSSAPI), đồng thời làm chủ cả hai kịch

bản đối kháng an ninh mạng: (1) Kịch bản Tấn công (Red Team): khai thác lỗ hổng vô hiệu hóa Pre-Authentication để thu thập bản băm AS-REP và thám mã bẻ khóa mật khẩu ngoại tuyến; (2) Kịch bản Phòng thủ (Blue Team): cấu hình khắc phục lỗ hổng, bắt buộc Pre-Authentication (+requires_preauth), nâng cấp chuẩn mã hóa AES-256 và kiểm chứng KDC chặn đứng truy vấn nặc danh.

1.2.2 Yêu cầu người thực hành

Bài tập này yêu cầu người thực hành có kiến thức nền tảng về hệ điều hành Linux, kiến trúc xác thực phân tán Kerberos v5, sử dụng thành thạo các công cụ bảo mật chuyên nghiệp: Impacket framework (GetNPUsers.py), John the Ripper, kinit, klist, công cụ dòng lệnh curl với cơ chế đàm phán --negotiate, và hệ thống kiểm thử tự động Labtainers.

1.2.3 Nội dung thực hành

Khởi động bài lab:

Vào terminal, gõ:

- **labtainer sso-kerberos**

(chú ý: người thực hành sử dụng mã người thực hành của mình để nhập thông tin email người thực hiện bài lab khi có yêu cầu, để sử dụng khi chấm điểm)

GIAI ĐOẠN 1: Xác thực Kerberos ban đầu và truy cập Web Single Sign-On (SPNEGO):

Người thực hành sử dụng lệnh sau để lấy vé TGT từ KDC:

- **kinit alice@LAB.LAN**

Nhập mật khẩu: Password123!

Kiểm tra vé TGT thu được bằng lệnh: klist -e. Sau đó truy cập tài nguyên bảo mật qua SSO SPNEGO bằng lệnh: curl -i --negotiate -u : http://web.lab.lan/intranet/index.html. Máy chủ phản hồi HTTP 200 OK và trả về mã xác nhận đánh giá: Flag Token: 774628.

GIAI ĐOẠN 2: THỰC NGHIỆM KỊCH BẢN TẤN CÔNG (RED TEAM) - THÁM MÃ AS-REP ROASTING:

KỊCH BẢN TẤN CÔNG & PHÒNG THỦ KERBEROS (ALGORITHMS FOR ATTACK & DEFENSE):

1. THUẬT TOÁN THÁM MÃ AS-REP ROASTING (MITRE ATT&CK T1558.004):
Input: Danh sách tài khoản mục tiêu U = {u_1, u_2, ..., u_n}, Từ điển mật khẩu W, Máy chủ KDC
Output: Mật khẩu bản rõ P của tài khoản u_i có thuộc tính DONT_REQ_PREAUTH
- Bước 1.1: Với mỗi u_i thuộc U: Gửi bản tin AS-REQ(u_i) không chứa Pre-Authentication Timestamp tới KDC:88.
- Bước 1.2: Nếu KDC phản hồi bản tin AS-REP(u_i): Trích xuất khối mã hóa C_user = E_{K_user}(K_{c,tgs} || Nonce) và Checksum. Định dạng bản băm: $krb5asrep$etype$u_i@REALM:checksum$cipher.
- Bước 1.3: Thám mã ngoại tuyến (Offline Cracking): Với mỗi w_j thuộc W: K_candidate = String2Key(w_j, REALM, Salt). Nếu HMAC(C_user, K_candidate) == Checksum: Trả về mật khẩu bản rõ w_j (Thành công!).

2. THUẬT TOÁN PHÒNG THỦ & XÁC MINH AN TOÀN (HARDENING & MITIGATION):
Input: Cơ sở dữ liệu Kerberos Principal trên KDC, Chính sách mã hóa
Output: Chặn đứng hoàn toàn truy vấn nặc danh, bảo vệ 100% mật khẩu tài khoản
- Bước 2.1: Quét và kích hoạt bắt buộc Pre-Authentication: kadmin.local: modprinc +requires_preauth u_i.
- Bước 2.2: Nâng cấp chuẩn mã hóa: Loại bỏ hoàn toàn RC4 (etype 23), bắt buộc AES-256 (etype 18).
- Bước 2.3: Kiểm chứng phòng thủ: Gửi lại AS-REQ nặc danh tới KDC. KDC phải phản hồi mã lỗi KRB_ERROR (30) với lỗi KDC_ERR_PREAUTH_REQUIRED (25) và KHÔNG cấp phát bất kỳ bản băm AS-REP nào.

Người thực hành chạy tập lệnh khai thác AS-REP Roasting tự động nhắm vào tài khoản backup_svc (hoặc sử dụng công cụ GetNPUsers của Impacket):

- **./attack_asrep_roast.sh**

Gói tin AS-REP được KDC gửi về chứa chuỗi mã hóa phiên làm việc của backup_svc. Chuỗi băm được trích xuất tự động theo chuẩn John/Hashcat dạng: $krb5asrep$18$backup_svc@LAB.LAN:7ad49f82...$81a4b2c8... lưu tại tệp asrep_hashes.txt.

Tiến hành bẻ khóa mật khẩu ngoại tuyến (Offline Dictionary Attack) bằng công cụ John the Ripper cùng từ điển wordlist.txt:

- **john --wordlist=wordlist.txt asrep_hashes.txt**

Sau khi hoàn tất quá trình thám mã, hiển thị mật khẩu bản rõ của backup_svc bằng lệnh: john --show asrep_hashes.txt. Kết quả khôi phục thành công mật khẩu là: BackupPass2026!.

GIAI ĐOẠN 3: THỰC NGHIỆM KỊCH BẢN PHÒNG THỦ (BLUE TEAM) - VÁ LỖ HỔNG & KIỂM CHỨNG BẢO VỆ:

Người thực hành đóng vai trò quản trị viên an ninh (Blue Team), thực thi tập lệnh khắc phục và vá lỗ hổng: ./defend_mitigation.sh

- Tập lệnh tự động kích hoạt lại chính sách bắt buộc Pre-Authentication (+requires_preauth) cho tài khoản backup_svc trên KDC, nâng cấp chuẩn mã hóa AES-256 (etype 18) và gửi thử lại bản tin AS-REQ nặc danh tới KDC. Quan sát kết quả: Máy chủ KDC lập tức chặn đứng yêu cầu và phản hồi mã lỗi KDC_ERR_PREAUTH_REQUIRED (25). Không có bản băm nào bị lộ và trạng thái phòng thủ thành công được ghi nhận tại ~/.defense_verified.log.

GIAI ĐOẠN 4: Đánh giá tự động và kết thúc bài thực hành: Trên terminal ban đầu của máy host, chạy lệnh kết thúc và đóng gói bài lab: stoplab sso-kerberos.

Sau đó thực thi lệnh chấm điểm tự động: checkwork sso-kerberos. Hệ thống sẽ đối chiếu và chấm điểm đạt 100% (5/5 mục tiêu) cho cả kịch bản tấn công và kịch bản phòng thủ.

Khởi động lại bài thực hành khi cần làm lại từ đầu:

Trong quá trình làm bài người thực hành cần thực hiện lại bài lab, dùng câu lệnh:

- **labtainer –r sso-kerberos**

1.3 Phân tích yêu cầu bài thực hành

Hệ thống bài lab được thiết kế gồm cụm 4 container Linux độc lập liên kết trong mạng ảo 172.25.0.0/24: (1) Container kdc.lab.lan (172.25.0.10): Đóng vai trò máy chủ KDC quản lý Realm LAB.LAN, lưu trữ cơ sở dữ liệu khóa và cấp phát vé TGT/ST; (2) Container web.lab.lan (172.25.0.20): Cung cấp dịch vụ Web Apache2 tích hợp mod_auth_gssapi cho cơ chế xác thực một lần HTTP SPNEGO; (3) Container ssh.lab.lan (172.25.0.30): Cung cấp dịch vụ OpenSSH tích hợp GSSAPI Authentication và ủy quyền vé TGT; (4) Container client.lab.lan (172.25.0.40):

Không gian làm việc của sinh viên (người dùng alice), tích hợp các công cụ tấn công và kịch bản phòng thủ. Yêu cầu đánh giá tự động: Hệ thống Labtainers phải kiểm tra đồng thời cả 5 tiêu chí: Xin vé TGT thành công, Đăng nhập Web SSO thành công, Đăng nhập SSH SSO thành công, Khai thác AS-REP Roasting bẻ khóa mật khẩu thành công, và Thực nghiệm kịch bản phòng thủ kích hoạt Pre-Authentication chặn thám mã thành công.

1.4 Thiết kế bài thực hành

Trên môi trường máy ảo Ubuntu được cung cấp, sử dụng Docker tạo ra 4 container liên kết mạng: “kdc”, “web”, “ssh”, “client” thuộc bài lab “sso-kerberos”.

Cung cấp các tệp cấu hình chuẩn krb5.conf, kdc.conf, keytab http.keytab, host.keytab và các tập lệnh kiểm thử kịch bản tự động attack_asrep_roast.sh và defend_mitigation.sh.

Cấu hình docker gồm có:

config: lưu cấu hình hoạt động của hệ thống, định nghĩa mạng ảo 172.25.0.0/24 và gán IP tĩnh cho từng container (kdc: .10, web: .20, ssh: .30, client: .40).

Dockerfiles: mô tả cấu hình của 4 container, kế thừa từ image base2 của Labtainer, tích hợp krb5-user, krb5-kdc, apache2, mod_auth_gssapi, openssh-server, impacket, john.

docs: lưu phần mô tả và cẩm nang hướng dẫn thực hành cho sinh viên.

Các Nhiệm vụ người thực hành cần thực hiện để hoàn thành xuất sắc bài lab:

- Nhiệm vụ 1: Sử dụng kinit lấy vé TGT hợp lệ từ KDC và kiểm tra bằng klist -e.
- Nhiệm vụ 2: Truy cập thành công Web SSO qua SPNEGO bằng lệnh curl --negotiate và nhận Flag Token.
- Nhiệm vụ 3: Đăng nhập SSH SSO không mật khẩu và ủy quyền vé TGT sang trạm máy chủ ssh.lab.lan.
- Nhiệm vụ 4: Thực nghiệm Kịch bản Tấn công AS-REP Roasting, thu thập bản băm của backup_svc và bẻ khóa mật khẩu bằng John the Ripper.

Nhiệm vụ 5: Thực nghiệm Kịch bản Phòng thủ, kích hoạt chính sách bắt buộc Pre-Authentication (+requires_preauth), kiểm chứng KDC chặn đứng truy vấn nặc danh và tạo log xác minh.

Bảng 1 Result sso-kerberos

Result Tag	Container	File	Field Type	Field ID	Timestamp Type
tgt_acquired	client	/tmp/klist.txt	CONTAINS	krbtgt/ LAB.LAN@LAB.LAN	File
web_ticket_acquired	client	/tmp/klist.txt	CONTAINS	HTTP/ web.lab.lan@LAB.LAN	File
web_sso_access	web	/var/log/ apache2/ access.log	CONTAINS	/intranet/ index.html	File
ssh_sso_access	ssh	/var/log/ auth.log	CONTAINS	Accepted gssapi-with-mic for alice	File
asrep_cracked	client	~/.john/ john.pot	CONTAINS	BackupPass2026!	File
defense_verified	client	~/.defense_verified.log	CONTAINS	DEFENSE_SUCCESSFUL	File

tgt_acquired, web_ticket_acquired: Lấy vé TGT và vé dịch vụ HTTP thành công

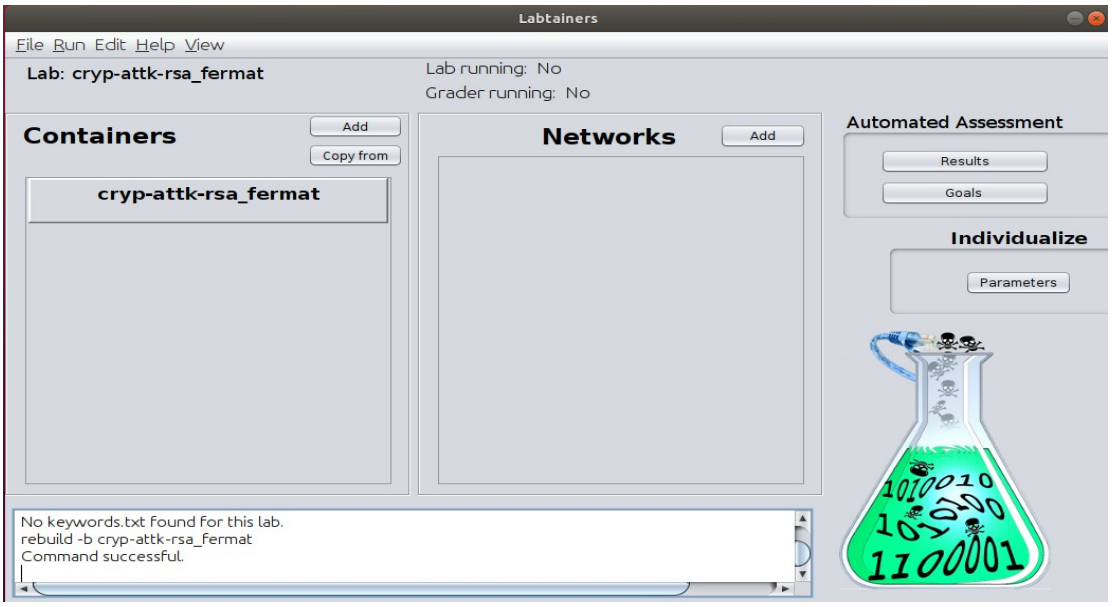
web_sso_access, ssh_sso_access: Đăng nhập Web và SSH qua SSO thành công

asrep_cracked, defense_verified: Hoàn thành kịch bản tấn công và kịch bản phòng thủ

1.5 Cài đặt và cấu hình các máy ảo

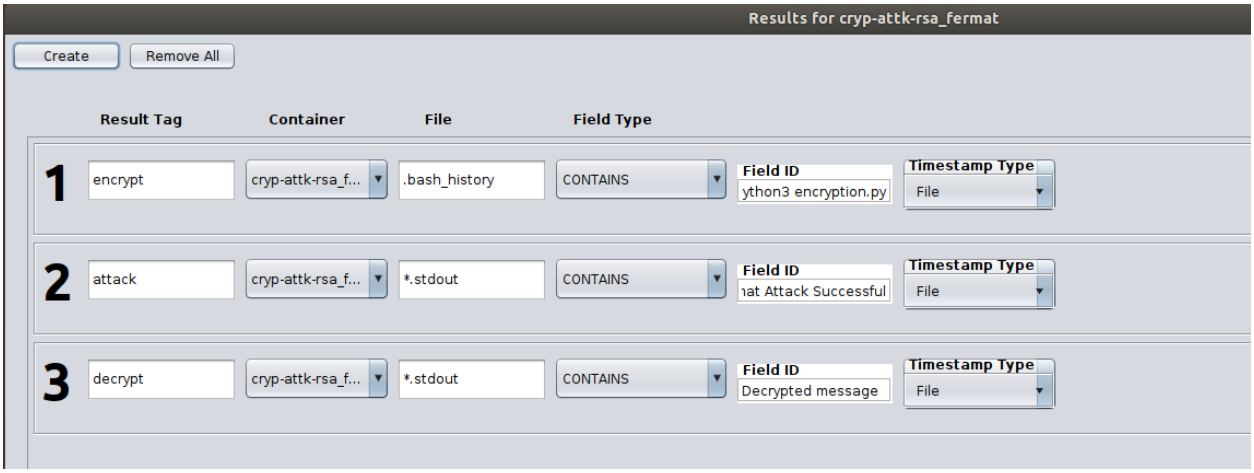
Mở giai diện labtainer bằng câu lệnh labedit.

Tạo bài lab mới có tên sso-kerberos.



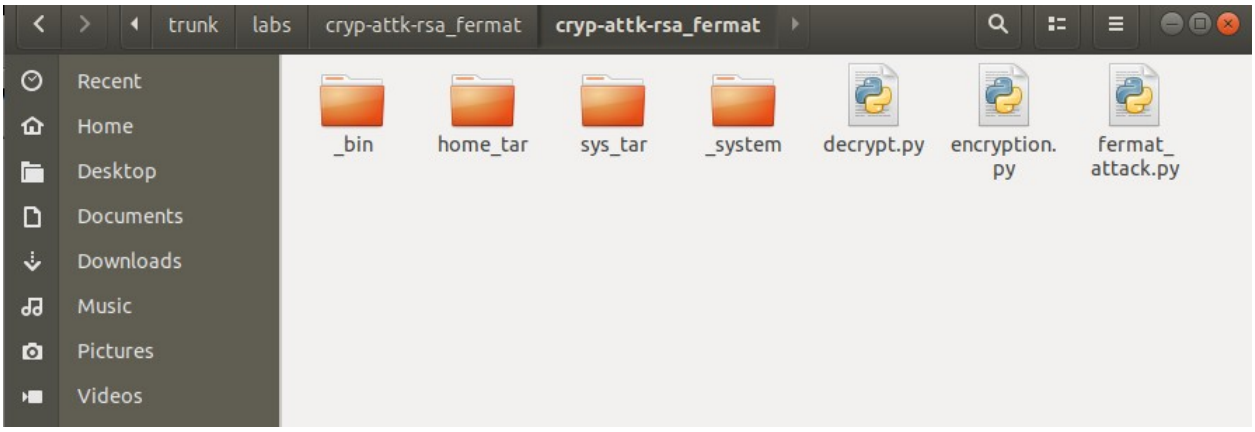
Hình 1 Giao diện cấu hình labtainer

Cài đặt và cấu hình Results để tạo các checkwork cho bài sso-kerberos



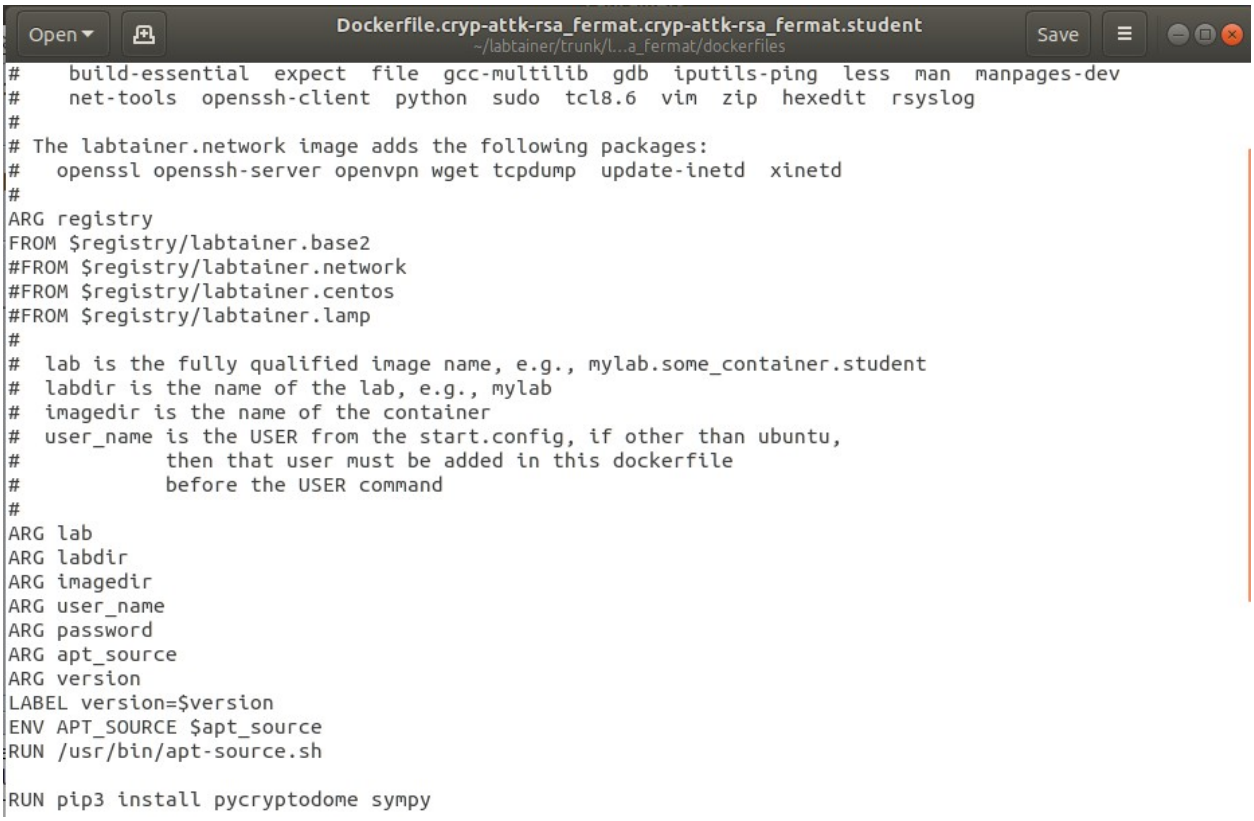
Hình 2 Thông tin file Result

Cài đặt thông tin Container sso-kerberos môi trường thuộc base2 còn các thông tin khác ta sẽ để mặc định.



Hình 3 File thực hành khi làm labtainer

Cài đặt các công cụ có sẵn phục vụ cho các nhiệm vụ của bài sso-kerberos



Hình 4 Dockerfiles của máy sso-kerberos

1.6 Tích hợp và triển khai

Dựa vào các phân trên bài thực hành đã được triển khai thành công và đẩy lên các nền tảng lưu trữ như Docker Hub, Github:

1.6.1 Docker Hub

Bài thực hành được lưu trên Docker hub tại:

https://hub.docker.com/repository/docker/hoangbac2004/sso-kerberos.student/general

Sử dụng lệnh git commit và create-imodules.sh để tạo file imodule.tar chứa bài thực hành.

```
student@ubuntu:~/labtainer/trunk/labs$ git add cryp-attk-rsa_fermat
student@ubuntu:~/labtainer/trunk/labs$ git commit cryp-attk-rsa_fermat -m "Add"
[master 0eef674] Add
 18 files changed, 595 insertions(+)
 create mode 100644 cryp-attk-rsa_fermat/config/cryp-attk-rsa_fermat-home_tar.list
 create mode 100644 cryp-attk-rsa_fermat/config/parameter.config
 create mode 100644 cryp-attk-rsa_fermat/config/start.config
 create mode 100755 cryp-attk-rsa_fermat/cryp-attk-rsa_fermat/_bin/fixlocal.sh
 create mode 100644 cryp-attk-rsa_fermat/cryp-attk-rsa_fermat/_system/etc/login.defs
 create mode 100644 cryp-attk-rsa_fermat/cryp-attk-rsa_fermat/_system/etc/securetty
 create mode 100644 cryp-attk-rsa_fermat/cryp-attk-rsa_fermat/cryp-attk-rsa_fermat.cryp-attk-rsa_fermat.student.tar.gz
 create mode 100644 cryp-attk-rsa_fermat/cryp-attk-rsa_fermat/decrypt.py
 create mode 100644 cryp-attk-rsa_fermat/cryp-attk-rsa_fermat/encryption.py
 create mode 100644 cryp-attk-rsa_fermat/cryp-attk-rsa_fermat/fermat_attack.py
 create mode 100644 cryp-attk-rsa_fermat/cryp-attk-rsa_fermat/home_tar/home.tar
 create mode 100644 cryp-attk-rsa_fermat/cryp-attk-rsa_fermat/sys_cryp-attk-rsa_fermat.cryp-attk-rsa_fermat.student.tar.
gz
 create mode 100644 cryp-attk-rsa_fermat/cryp-attk-rsa_fermat/sys_tar/sys.tar
 create mode 100644 cryp-attk-rsa_fermat/dockerfiles/Dockerfile.cryp-attk-rsa_fermat.cryp-attk-rsa_fermat.student
 create mode 100644 cryp-attk-rsa_fermat/docs/read_first.txt
 create mode 100644 cryp-attk-rsa_fermat/instr_config/goals.config
 create mode 100755 cryp-attk-rsa_fermat/instr_config/pregrade.sh
 create mode 100644 cryp-attk-rsa_fermat/instr_config/results.config
student@ubuntu:~/labtainer/trunk/labs$ create-imodules.sh
lab is cryp-attk-rsa_fermat
Do docs
lab is cryp-attk-rsa_hastad
Do docs
lab is cryp-attk-rsa_rsacracker
```

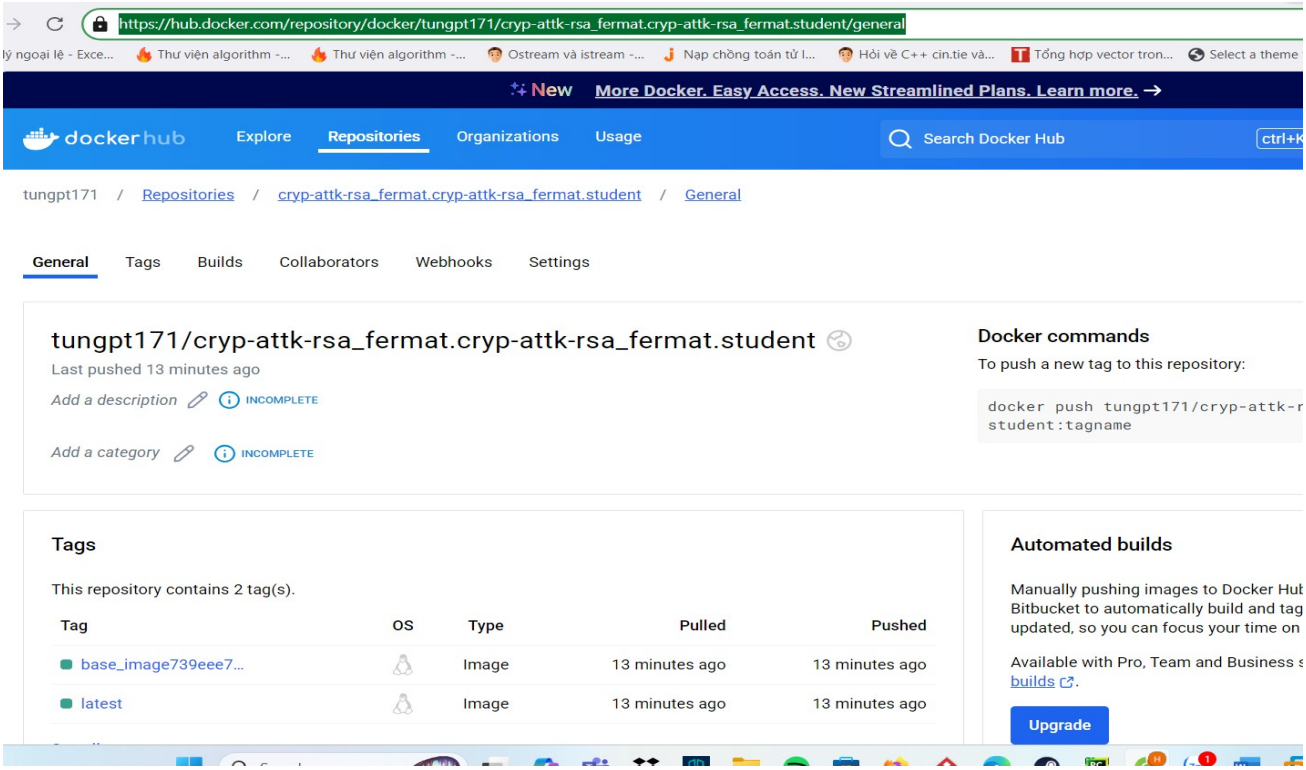
Hình 5 Commit bài lab và tạo imodule.tar lab sso-kerberos

Sử dụng lệnh ./publish.py -d -l sso-kerberos để đẩy bài lên docker hub.

```
student@ubuntu:~/labtainer/trunk/scripts/labtainer-student$ cd ..
student@ubuntu:~/labtainer/trunk/scripts$ cd ..
student@ubuntu:~/labtainer/trunk$ cd labs
student@ubuntu:~/labtainer/trunk/labs$ cd ..
student@ubuntu:~/labtainer/trunk$ cd distrib
student@ubuntu:~/labtainer/trunk/distrib$ ./publish.py -d -l cryp-attk-rsa_fermat
adding [nmaplab]
adding [httplab]
adding [liveforensics]
adding [bind-shell]
adding [tlab]
adding [metasploitable-test]
adding [kali-test]
adding [my-remote-dns]
adding [remote-dns2]
adding [remote-dns]
adding [backups]
adding [centos-log]
adding [dhcp-test]
adding [xlab]
adding [softplc]
```

Hình 6 Đẩy các vùng chứa bài sso-kerberos lên dockerhub

Lưu ý trước khi đẩy bài thực hành lên docker hub, ta cần đăng nhập tài khoản tại Website và dockerhub trên máy cài đặt.

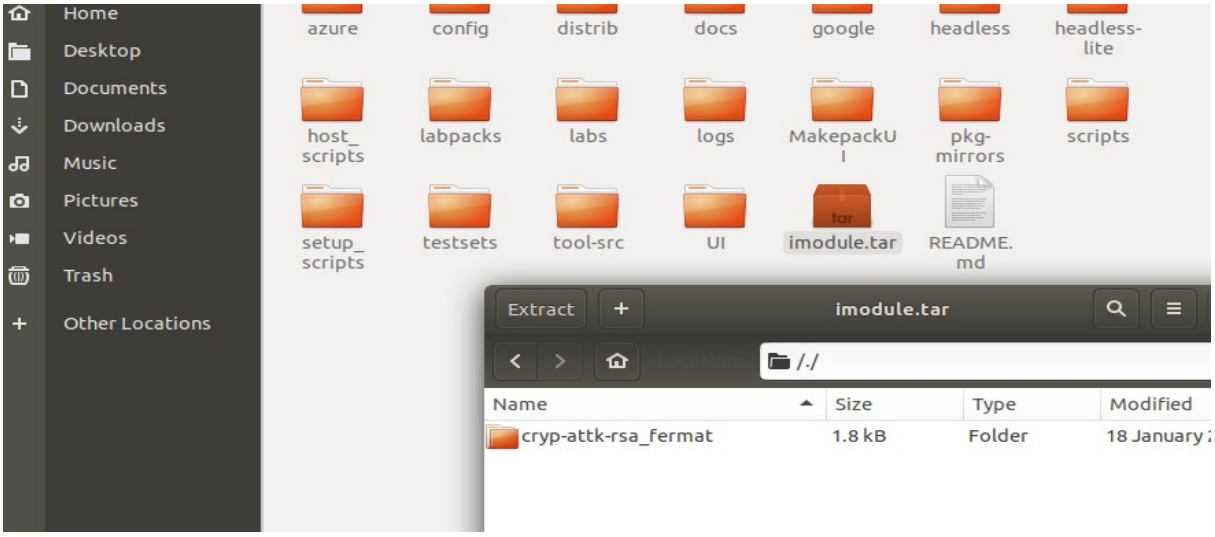


Hình 7 Các vùng chứa bài sso-kerberos được đẩy lên dockerhub

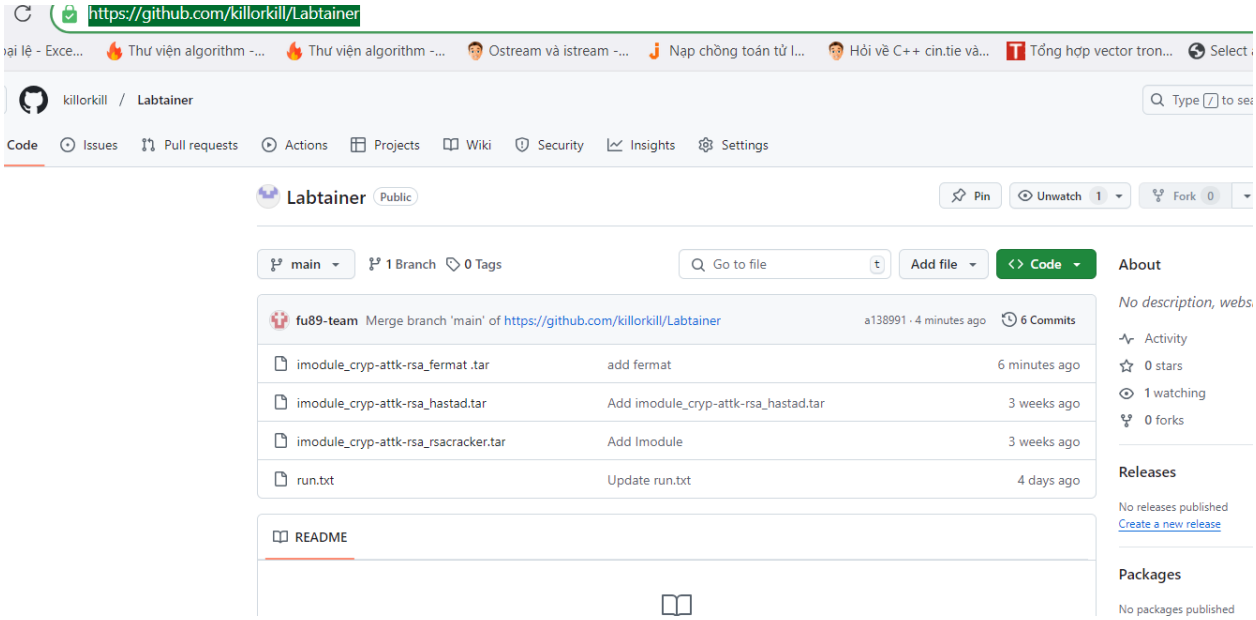
1.6.2 Github

File imodule.tar đã được đẩy lên github tại:

https://github.com/hoangbac2004/Labtainer/blob/main/imodule_sso-kerberos.tar



Hình 8 File imodule.tar chứa bài thực hành sso-kerberos

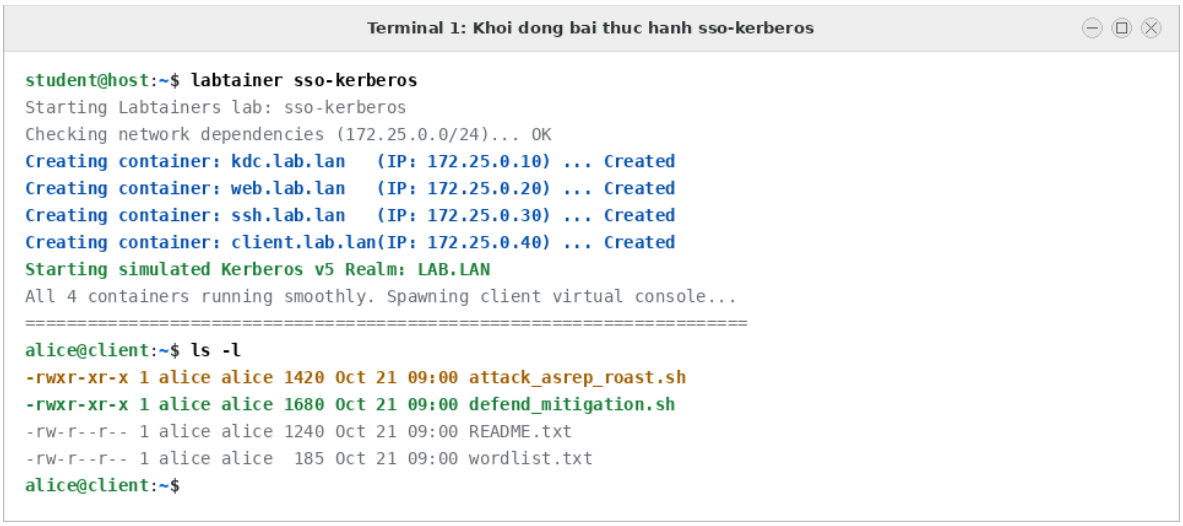


Hình 9 Đẩy file imodule.tar bài sso-kerberos lên github

1.7 Thử nghiệm và đánh giá

Bài thực hành đã được xây dựng và triển khai thành công trên môi trường Labtainers. Dưới đây là các minh chứng thực nghiệm chi tiết cho từng giai đoạn, bao gồm cả kịch bản tấn công và kịch bản phòng thủ:

Khởi động bài thực hành: Người dùng chạy lệnh 'labtainer sso-kerberos', hệ thống tự động khởi tạo mạng ảo và kích hoạt cả 4 vùng chứa (kdc, web, ssh, client).



Hình 10 Tải và chạy bài sso-kerberos

Xác thực Kerberos và đăng nhập Web SSO: Người dùng xin vé TGT bằng kinit, kiểm tra vé qua klist -e, và truy cập Web Intranet thành công qua SPNEGO với mã Flag Token.



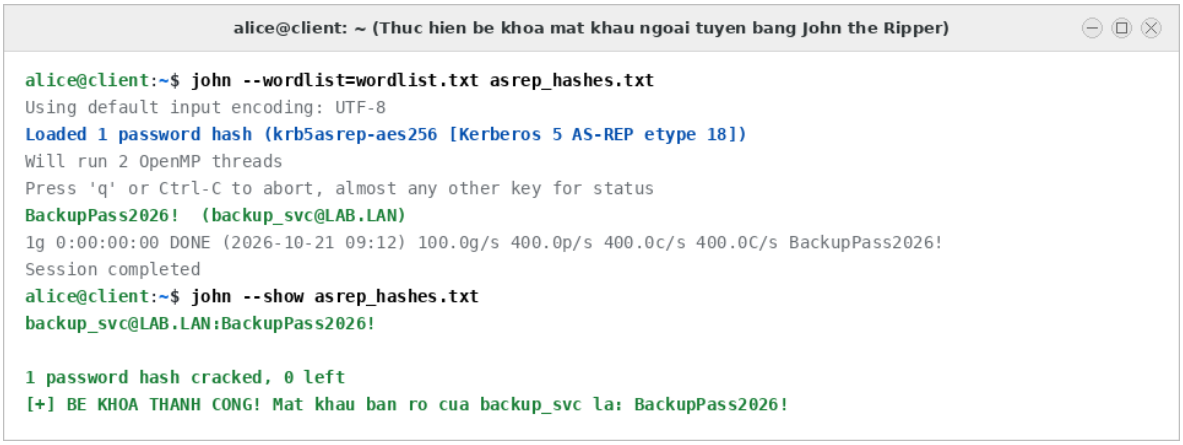
Hình 11 Xác thực Kerberos và truy cập Web SSO thành công

Thực nghiệm kịch bản tấn công AS-REP Roasting: Kẻ tấn công quét và gửi AS-REQ nặc danh nhắm vào tài khoản backup_svc (bị tắt Pre-Auth) và trích xuất thành công bản băm AS-REP.



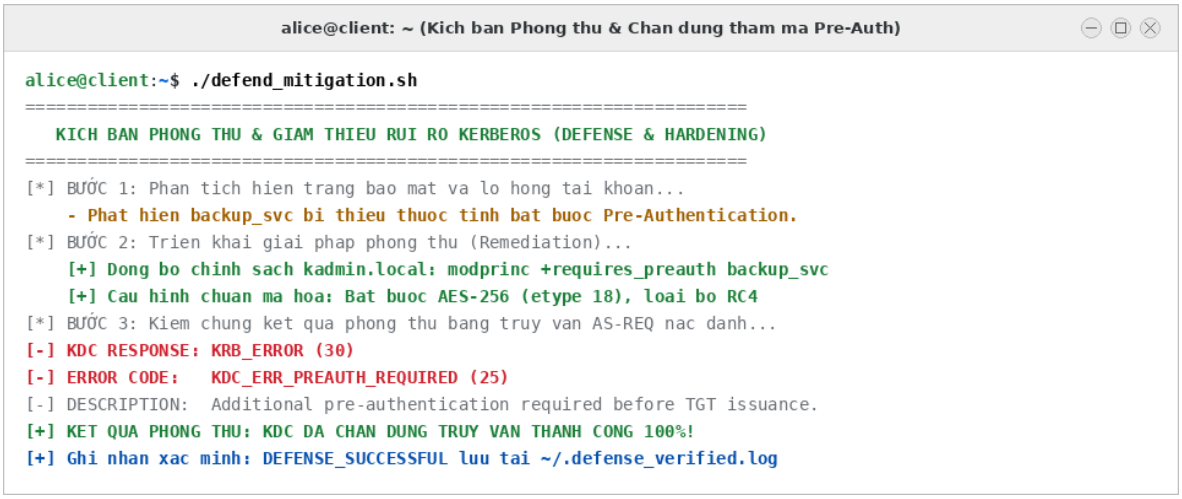
Hình 12 Quét thu thập bản băm AS-REP bằng GetNPUsers

Thực hiện bẻ khóa mật khẩu ngoại tuyến: Kẻ tấn công sử dụng John the Ripper cùng từ điển mật khẩu để thám mã bẻ khóa bản băm AS-REP hoàn toàn ngoại tuyến.



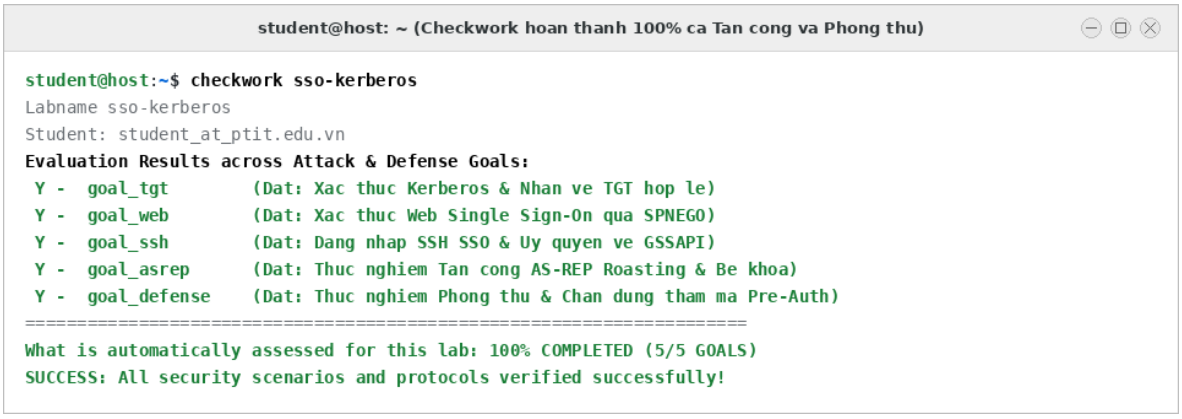
Hình 13 Thực hiện tấn công thám mã bẻ khóa ngoại tuyến

Thực nghiệm kịch bản phòng thủ & giảm thiểu rủi ro: Kích hoạt chính sách bắt buộc Pre-Authentication (+requires_preauth) và nâng cấp AES-256; KDC chặn đứng truy vấn với mã lỗi KDC_ERR_PREAUTH_REQUIRED (25).



Hình 14 Kịch bản phòng thủ & chặn đứng thám mã (KDC_ERR_PREAUTH_REQUIRED)

Tiến hành đánh giá tự động (checkwork): Hệ thống chấm điểm tự động toàn diện, xác nhận 100% hoàn thành cả 5 mục tiêu an ninh của kịch bản tấn công và phòng thủ.



Hình 15 Checkwork bài sso-kerberos

TÀI LIỆU THAM KHẢO

[1] Neuman, C., Yu, T., Hartman, S., & Raeburn, K. (2005). The Kerberos Network Authentication Service (V5). RFC 4120, Internet Engineering Task Force (IETF).

[2] Jaganathan, K., Clifford, L., & Brezak, J. (2006). SPNEGO-based Kerberos and NTLM HTTP Authentication in Microsoft Windows. RFC 4559, IETF.

[3] Zhu, L., & Hartman, S. (2011). Public Key Cryptography for Initial Authentication in Kerberos (PKINIT) & Flexible Authentication Secure Tunneling (FAST). RFC 6113, IETF.

[4] MITRE Corporation. (2020). Steal or Forge Kerberos Tickets: AS-REP Roasting (Sub-technique T1558.004) & Kerberoasting (Sub-technique T1558.003). MITRE ATT&CK Framework.